
LAPORAN PRAKTIKUM
Analisis Alert Keamanan pada OWASP Juice Shop
Menggunakan Zed Attack Proxy (ZAP)

Diajukan sebagai Tugas untuk Mata Kuliah Ethical Hacking



Disusun Oleh:

Annaufal Afif Seno	2023071054
Khairun Nisa Al Hakim	2024071001
Qurratu Farrasah Siregar	2024071017

PROGRAM STUDI INFORMATIKA
FAKULTAS TEKNOLOGI DAN DESAIN
UNIVERSITAS PEMBANGUNAN JAYA

2026

LATAR BELAKANG

Keamanan aplikasi web merupakan salah satu aspek kritis dalam pengembangan sistem informasi modern. Ancaman terhadap aplikasi web terus berkembang, mulai dari injeksi skrip berbahaya, pencurian sesi pengguna, hingga akses tidak sah terhadap data sensitif. Praktikum ini dilakukan sebagai bagian dari mata kuliah Ethical Hacking untuk memberikan pengalaman langsung dalam mengidentifikasi dan menganalisis kerentanan keamanan pada aplikasi web.

OWASP Juice Shop merupakan aplikasi web yang sengaja dirancang dengan berbagai kerentanan keamanan untuk tujuan pembelajaran. Aplikasi ini mengimplementasikan celah keamanan nyata dari daftar OWASP Top 10, sehingga sangat tepat digunakan sebagai target latihan dalam lingkungan yang terkontrol dan aman.

OWASP ZAP (Zed Attack Proxy) adalah alat pengujian keamanan aplikasi web open-source yang dikembangkan oleh OWASP. ZAP menyediakan fitur pemindaian pasif, spider otomatis, dan analisis alert keamanan yang membantu pengujian mengidentifikasi berbagai celah keamanan secara sistematis. Dalam praktikum ini, browser Firefox dikonfigurasi untuk meneruskan seluruh lalu lintas HTTP melalui ZAP pada alamat 127.0.0.1 port 8090.

RUANG LINGKUP PENGUJIAN

Komponen	Detail
Tool	OWASP ZAP (Zed Attack Proxy)
Aplikasi Target	OWASP Juice Shop
Alamat Target	http://127.0.0.1:3000
Proxy	127.0.0.1 port 8090
Browser	Mozilla Firefox
Jenis Pengujian	Passive scan, spidering, analisis header, validasi manual
Batasan Aktivitas	Tidak melakukan brute force, tidak melakukan DoS, hanya menguji aplikasi latihan lokal, tidak menyentuh sistem publik atau kampus

Aktivitas yang Diperbolehkan

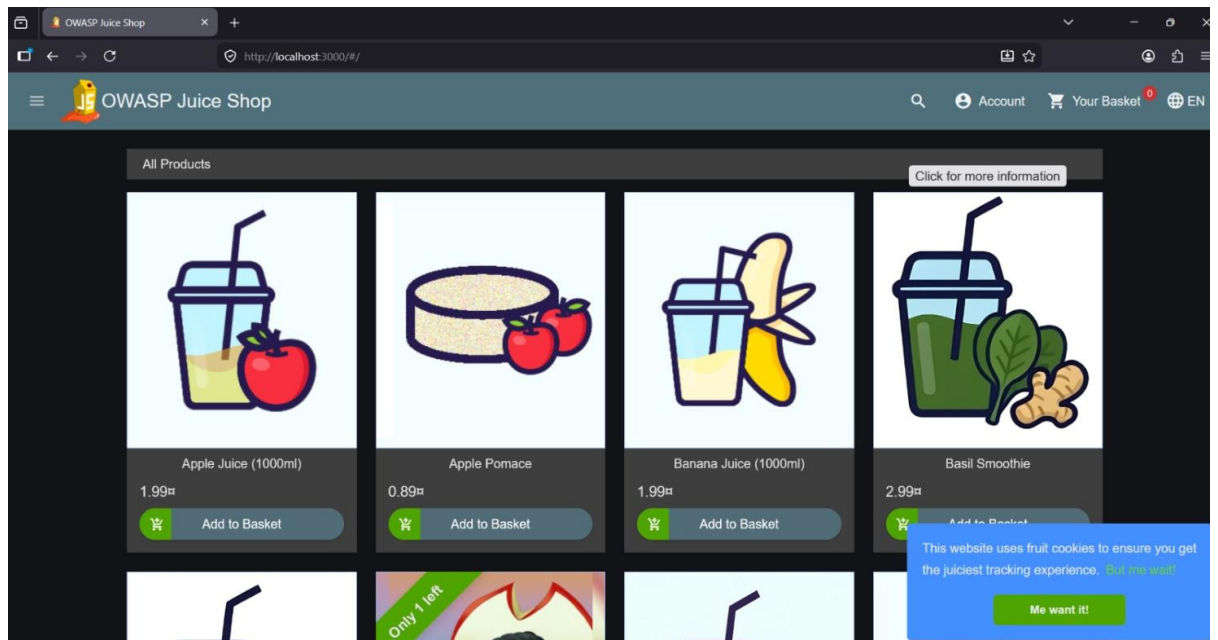
- a) Menguji aplikasi latihan lokal (OWASP Juice Shop)
- b) Mencatat request dan response HTTP
- c) Melakukan passive scan menggunakan ZAP
Melakukan spidering ringan pada aplikasi lab
- d) Menguji input sederhana pada form aplikasi
- e) Membuat analisis risiko dan rekomendasi perbaikan

Aktivitas yang Tidak Diperbolehkan

- a) Menguji website publik tanpa izin tertulis
 - b) Melakukan brute force terhadap sistem apapun
 - c) Melakukan DoS atau stress test
 - d) Mengambil data pribadi milik orang lain
 - e) Scanning jaringan kampus tanpa izin
-

LINGKUNGAN PRAKTIKUM

Aspek	Detail
Sistem Operasi	Windows 11
Browser	Mozilla Firefox
Versi Firefox	150.0.3
Tool Pengujian	OWASP ZAP
Versi ZAP	2.17.0
Aplikasi Target	OWASP Juice Shop
Versi Juice Shop	20.0.0
Metode Instalasi Target	Docker
URL Target	http://127.0.0.1:3000
Alamat Proxy ZAP	127.0.0.1:8090
RAM	16 GB

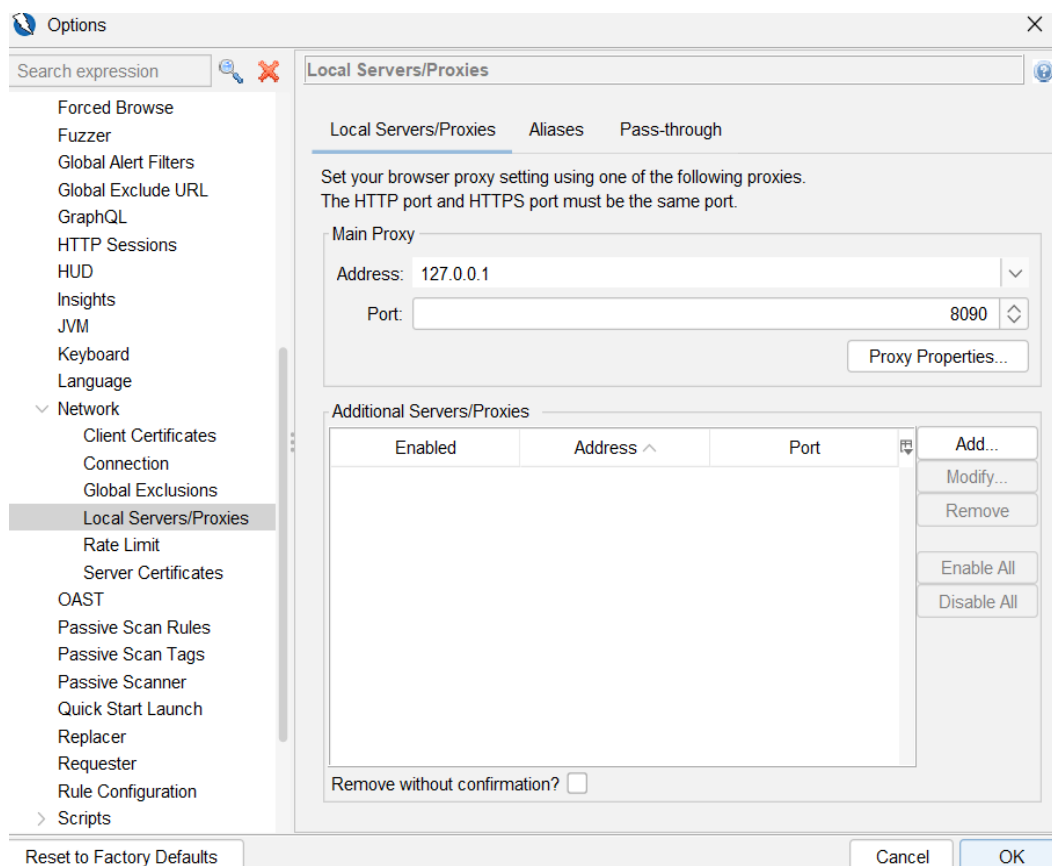


Gambar 1. Bukti Juice Shope Running.

LANGKAH KONFIGURASI PROXY

A. Konfigurasi Proxy pada OWASP ZAP

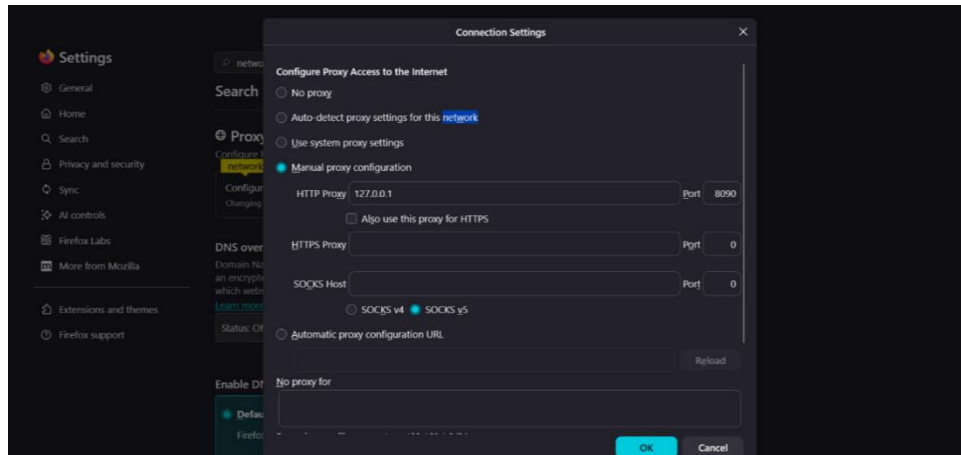
1. Buka aplikasi OWASP ZAP.
2. Masuk ke menu Tools > Options > Local Proxies (atau Network > Local Servers/Proxies pada versi terbaru).
3. Pastikan Address diisi 127.0.0.1 dan Port diisi 8090.
4. Klik OK untuk menyimpan pengaturan.



Gambar 2. Setting Proxy OWASP ZAP

B. Konfigurasi Proxy pada Firefox

1. Buka Firefox, masuk ke Settings > General > Network Settings > Settings.
 2. Pilih opsi Manual proxy configuration.
 3. Isi HTTP Proxy: 127.0.0.1, Port: 8090.
 4. Centang Also use this proxy for HTTPS (opsional, untuk traffic HTTPS).
 5. Klik OK untuk menyimpan.
-



Gambar 3. Setting Proxy OWASP ZAP

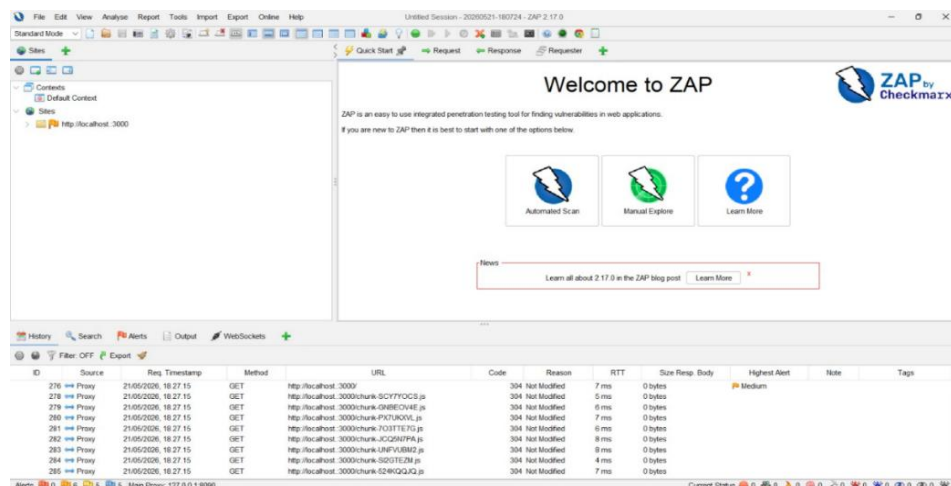
C. Instalasi Sertifikat ZAP

1. Di ZAP, masuk ke Tools > Options > Dynamic SSL Certificate.
2. Klik Generate dan Save untuk menyimpan sertifikat.
3. Di Firefox, masuk ke Settings > Privacy & Security > View Certificates > Import.
4. Impor file sertifikat ZAP yang sudah disimpan.
5. Centang Trust this CA to identify websites, klik OK.

D. Verifikasi Koneksi Proxy

Untuk memverifikasi proxy berfungsi:

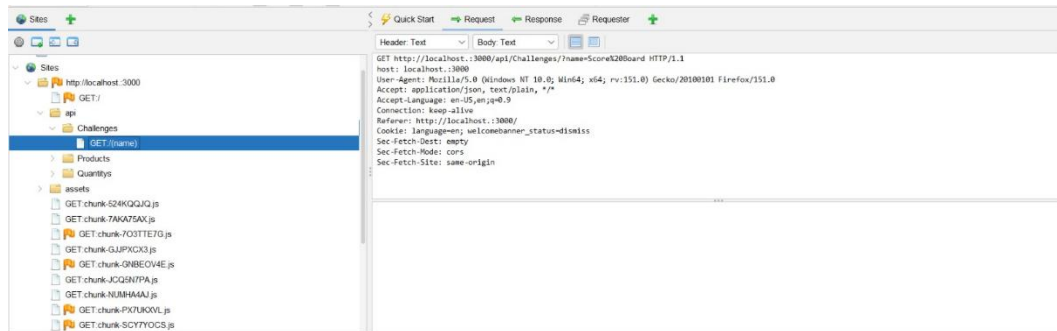
1. Buka Firefox dan akses <http://127.0.0.1:3000>.
2. Amati tab History atau Sites di ZAP — request dari browser seharusnya muncul.
3. Jika request tertangkap, konfigurasi berhasil.



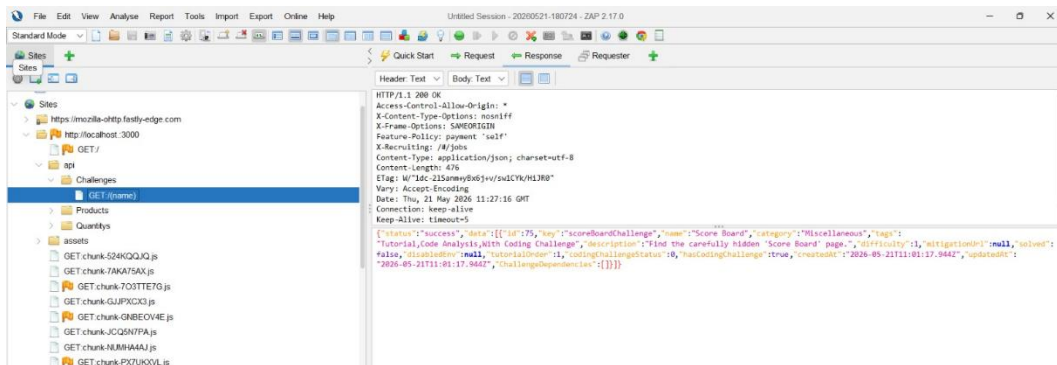
Gambar 4. ZAP dan Browser Telah Connect.

E. Bukti Request - Response

1. api/Challenges

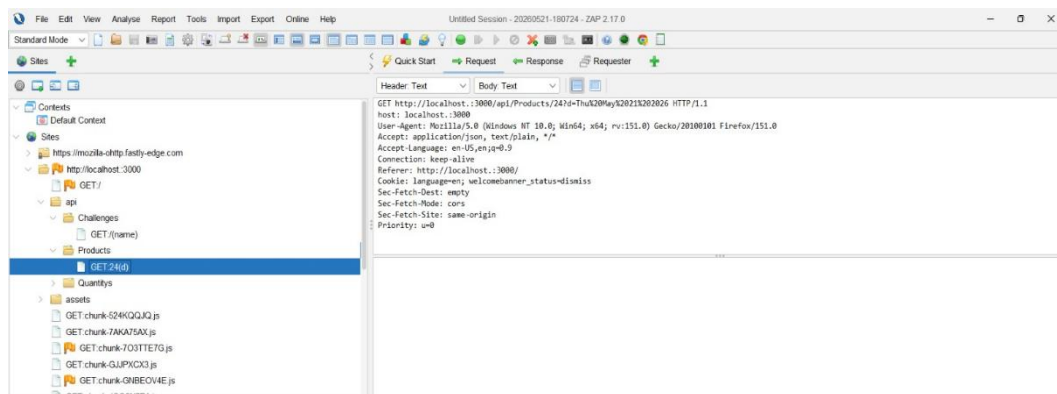


Gambar 5. GET Request ke Endpoint /api/Challenges.

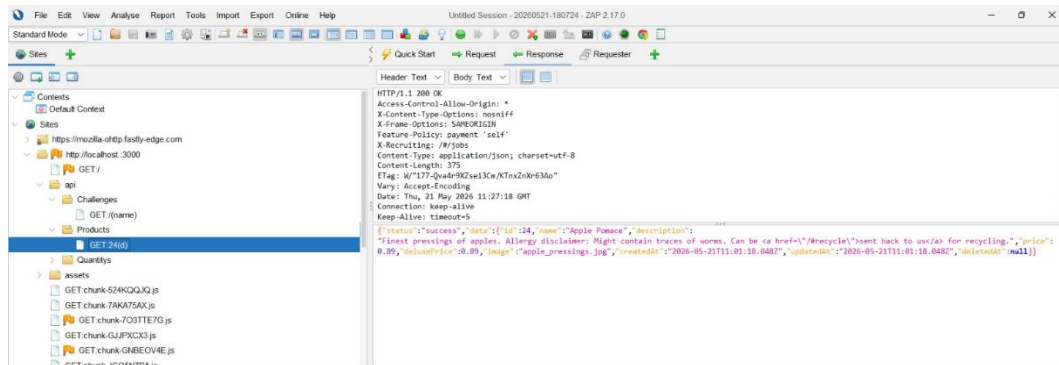


Gambar 6. GET Response ke Endpoint /api/Challenges.

2. api/Products

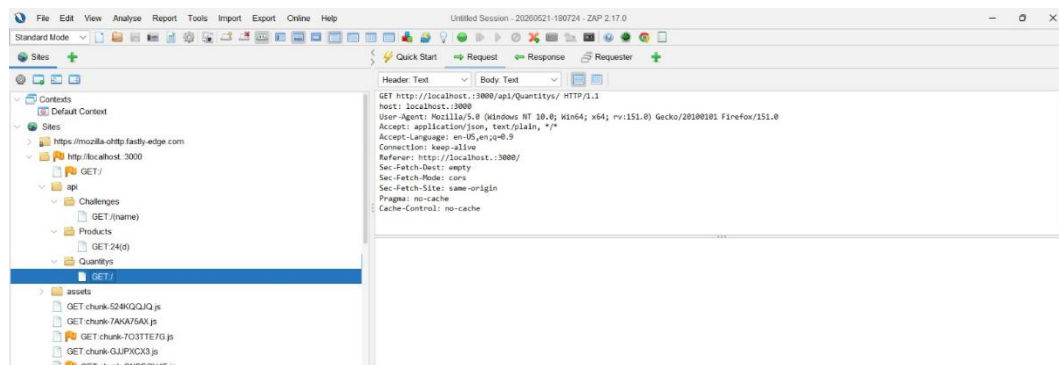


Gambar 7. GET Request ke Endpoint /api/Products.

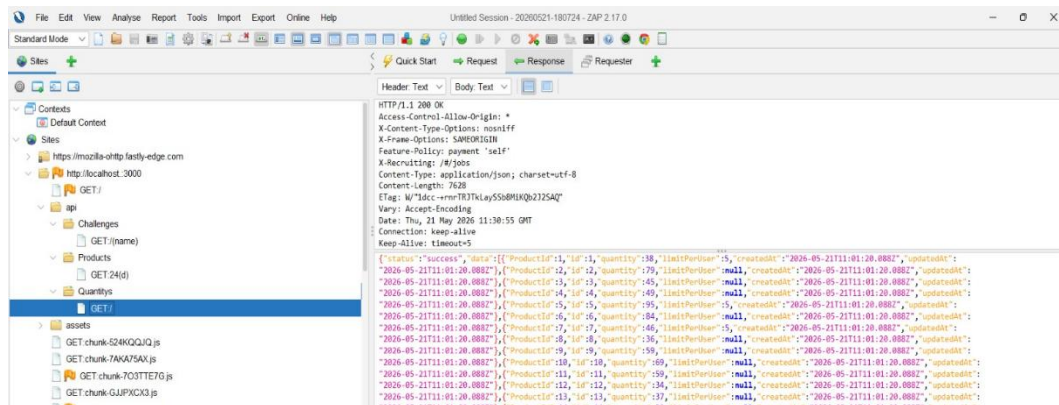


Gambar 8. GET Response ke Endpoint /api/Products.

3. api/Quantities.



Gambar 9. GET Request ke Endpoint /api/Quantities.



Gambar10. GET Response ke Endpoint /api/Quantities.

HASIL EKSPLORASI ENDPOINT

Tahapan Eksplorasi

Eksplorasi dilakukan terhadap OWASP Juice Shop pada alamat <http://127.0.0.1:3000> menggunakan fitur Manual Explore, Spider, dan pengamatan History di OWASP ZAP. Berikut adalah daftar endpoint yang berhasil diidentifikasi selama sesi pengujian.

Tabel Endpoint yang Ditemukan

No	Method	Endpoint	Parameter	Status	Keterangan
REGISTRASI & LOGIN					
1	GET	/#/login	—	200	Halaman login dimuat di browser
2	POST	/rest/user/login	email, password	200	Login berhasil — response mengandung token JWT & data user
3	POST	/rest/user/login	email (asal), password (asal)	401	Login gagal — kredensial salah
4	POST	/api/Users	email, password, passwordRepeat, securityQuestion, answer	200	Registrasi akun baru berhasil
PRODUK					
5	GET	/rest/products/search	q=	200	Melihat semua produk tanpa kata kunci
6	GET	/rest/products/search	q=apple	200	Pencarian produk dengan kata kunci "apple"
7	GET	/rest/products/search	q=apple' (tanda petik tunggal)	500	Karakter petik — indikasi SQL Injection
8	GET	/rest/products/search	q=xyznotfound	200	Pencarian produk yang tidak ada
PROFIL USER					
9	PUT	/api/Users/:id	username	200	Ubah username pada halaman profil
KERANJANG BELANJA					
10	POST	/api/BasketItems	ProductId, BasketId, quantity	200	Tambah produk ke keranjang
11	PUT	/api/BasketItems/:id	quantity	200	Update jumlah item di keranjang (tambah kuantitas)
12	DELETE	/api/BasketItems/:id	id item	200	Hapus item dari keranjang

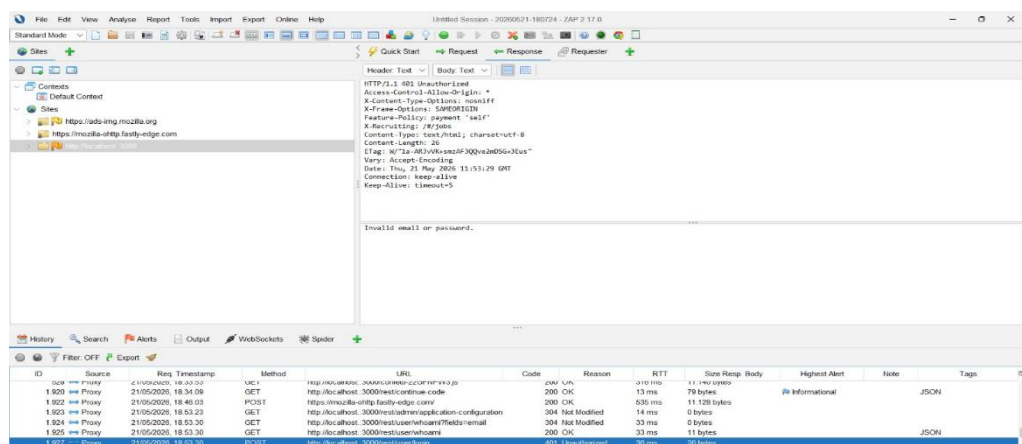
PERCOBAAN AKSES ADMIN (GAGAL)					
13	POST	/rest/user/login	email=admin@..., password (salah)	401	Percobaan login sebagai admin dengan password salah — ditolak
14	GET	/#/administration	—	401	Akses halaman admin tanpa login admin — ditolak / redirect

Bukti Eksplorasi

1. Halaman login

1.933	Prox	21/05/2020, 18.53.23	GET	http://localhost:3000/rest/admin/application-configuration	304 Not Modified	14 ms	0 bytes	
1.934	Prox	21/05/2020, 18.53.30	GET	http://localhost:3000/rest/user/whoami?fields=email	304 Not Modified	33 ms	0 bytes	
1.925	Prox	21/05/2020, 18.53.30	GET	http://localhost:3000/rest/user/whoami	200 OK	33 ms	11 bytes	JSON
1.927	Prox	21/05/2020, 18.53.30	POST	http://localhost:3000/rest/user/login	401 Unauthorized	36 ms	25 bytes	

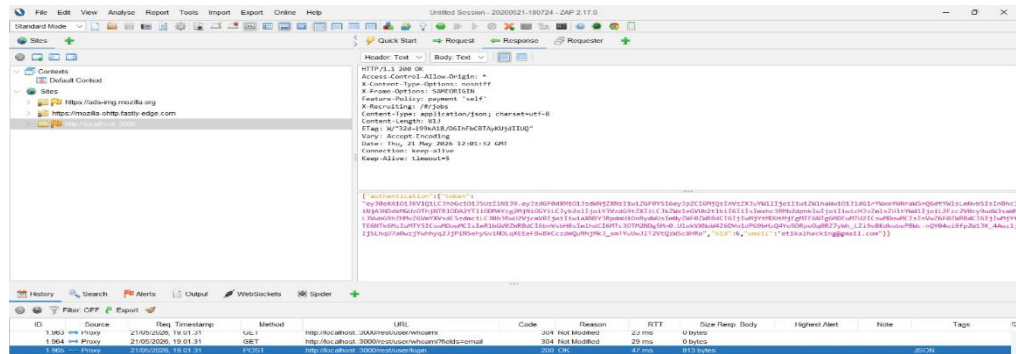
Gambar 11. History Saat Melakukan Login Asal



Gambar 12. Respon pada Post saat Login Asal

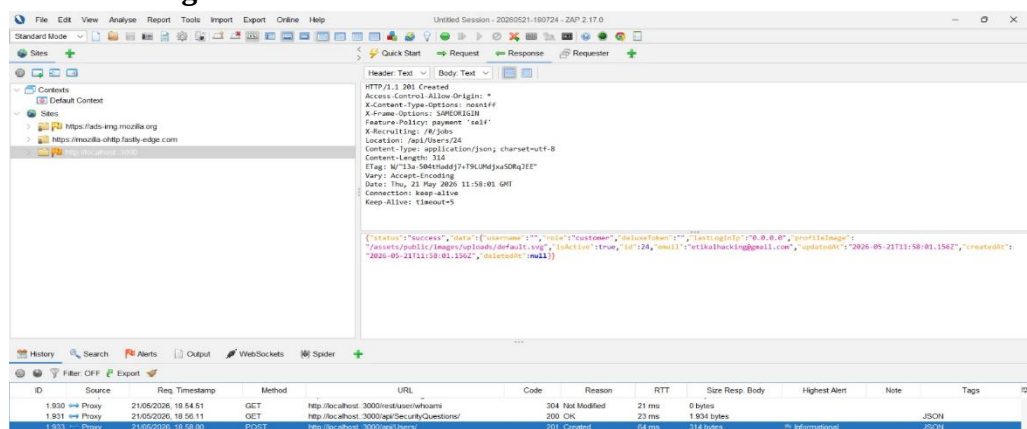
1.933	Prox	21/05/2020, 18.58.00	POST	http://localhost:3000/api/users/	201 Created	64 ms	314 bytes	Informational	JSON
1.935	Prox	21/05/2020, 18.58.00	POST	http://localhost:3000/api/security/recovery/	201 Created	57 ms	226 bytes		JSON
1.937	Prox	21/05/2020, 18.58.01	GET	http://localhost:3000/rest/admin/application-configuration	304 Not Modified	21 ms	0 bytes		
1.939	Prox	21/05/2020, 18.58.17	GET	http://localhost:3000/rest/user/whoami	304 Not Modified	17 ms	0 bytes		
1.934	Prox	21/05/2020, 18.58.17	GET	http://localhost:3000/rest/user/whoami?fields=email	304 Not Modified	21 ms	0 bytes		
1.940	Prox	21/05/2020, 18.58.17	POST	http://localhost:3000/rest/user/login	200 OK	69 ms	822 bytes	Informational	JSON

Gambar 13. History Saat Melakukan Regis dan Login Sukses



Gambar 14. Respon pada Post saat Login Sukses

2. Halaman Registrasi



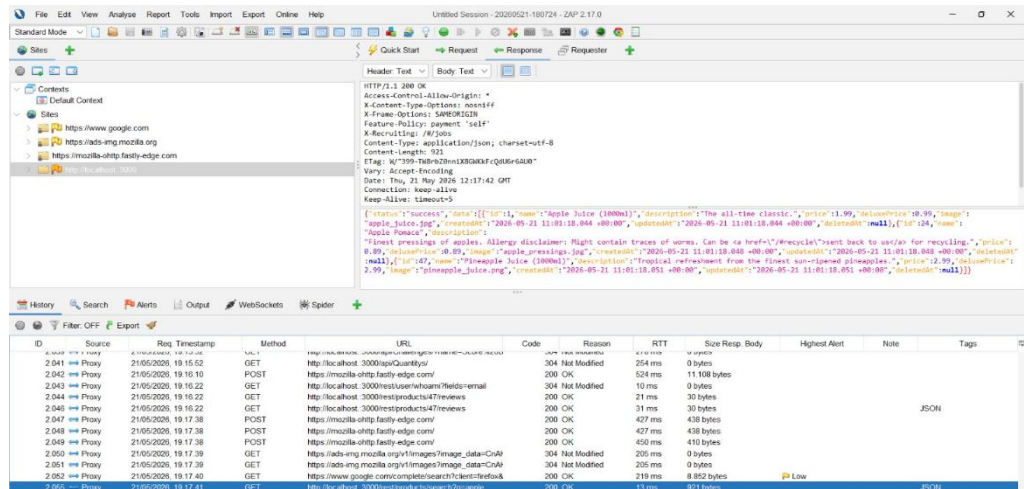
Gambar 15. Respon pada Post saat Registrasi

3. Halaman Produk

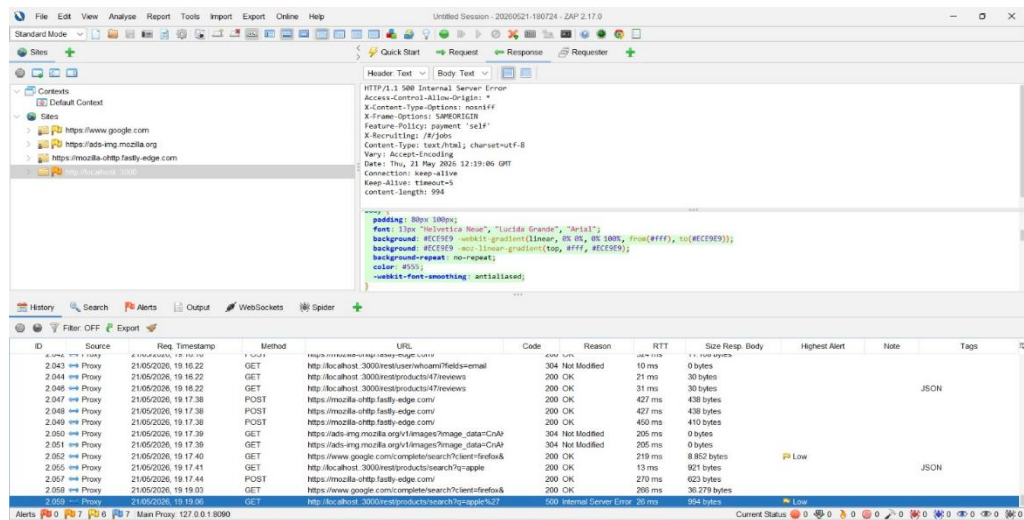
1971	Proxy	21/05/2020, 19:06:25	GET	http://localhost:3000/api/products/1/reviews	200 OK	26 ms	369 bytes		JSON
1972	Proxy	21/05/2020, 19:06:25	GET	http://localhost:3000/api/users/whoamI?fields=email	304 Not Modified	37 ms	0 bytes		
1974	Proxy	21/05/2020, 19:06:25	GET	http://localhost:3000/api/products/1/reviews	200 OK	51 ms	369 bytes		
1975	Proxy	21/05/2020, 19:06:25	GET	http://localhost:3000/api/products/1/reviews	304 Not Modified	11 ms	0 bytes		

Gambar 16. Respon pada Get Saat Melihat Salah Satu Produk

4. Halaman Pencarian



Gambar17. Respon pada Saat Mencari “apple”



Gambar18. Respon pada Saat Mencari “apple' ”(dengan tanda petik)

ID	Source	Req. Timestamp	Method	URL	Code	Reason	RTT	Size Resp. Body	Highest Alert	Note	Tags
2048	Proxy	21/05/2020, 19:17:39	POST	https://img-mozzila-ohp.fastly-edge.com/	200	OK	427 ms	438 bytes			
2049	Proxy	21/05/2020, 19:17:39	POST	https://img-mozzila-ohp.fastly-edge.com/	200	OK	450 ms	410 bytes			
2050	Proxy	21/05/2020, 19:17:39	GET	https://ads-imp.mozzila.org/v1/images?image_data=CrAb	304	Not Modified	205 ms	0 bytes			
2051	Proxy	21/05/2020, 19:17:39	GET	https://ads-imp.mozzila.org/v1/images?image_data=CrAb	304	Not Modified	205 ms	0 bytes			
2052	Proxy	21/05/2020, 19:17:40	GET	https://www.google.com/completesearch?client=firefox-a	200	OK	219 ms	8,852 bytes	Low		JSON
2053	Proxy	21/05/2020, 19:17:41	GET	http://localhost:3000/rest/products/search?q=apple	200	OK	13 ms	821 bytes			
2057	Proxy	21/05/2020, 19:17:44	POST	https://img-mozzila-ohp.fastly-edge.com/	200	OK	270 ms	623 bytes			
2058	Proxy	21/05/2020, 19:18:03	GET	https://www.google.com/completesearch?client=firefox-a	200	OK	266 ms	36,279 bytes	Low		
2059	Proxy	21/05/2020, 19:18:06	GET	http://localhost:3000/rest/products/search?q=apple&h27	500	Internal Server Error	25 ms	964 bytes			
2061	Proxy	21/05/2020, 19:20:53	GET	https://www.google.com/completesearch?client=firefox-a	200	OK	316 ms	30,041 bytes			
2062	Proxy	21/05/2020, 19:20:57	GET	http://localhost:3000/rest/products/search?q=modal	200	OK	14 ms	458 bytes			JSON

Gambar 19. Respon pada Saat Mencari Produk yang Tidak Ada

5. Halaman profil

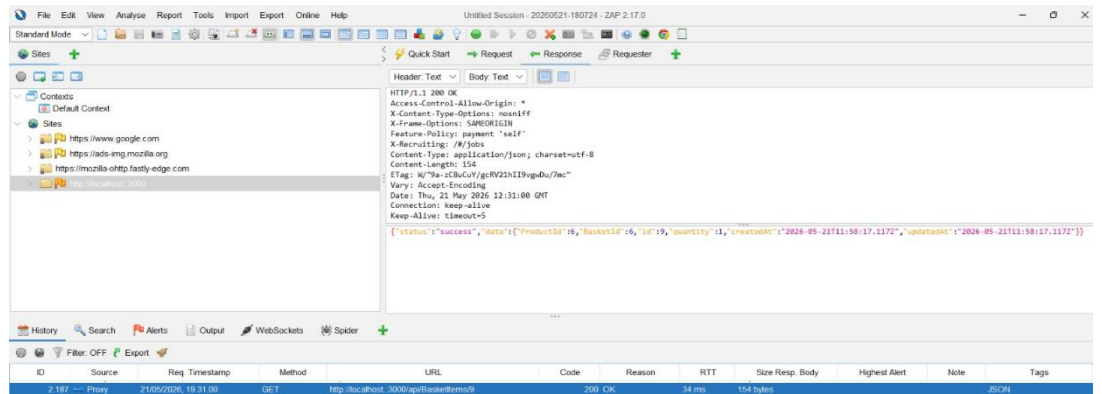
ID	Source	Req. Timestamp	Method	URL	Code	Reason	RTT	Size Resp. Body	Highest Alert	Note	Tags
2067	Proxy	21/05/2020, 19:23:18	GET	http://localhost:3000/profile	200	OK	196 ms	4,673 bytes	Medium		Form, Upload, Script, Com.
2068	Proxy	21/05/2020, 19:23:18	GET	http://localhost:3000/assets/public/css/userProfile.css	200	OK	8 ms	491 bytes			Comment
2069	Proxy	21/05/2020, 19:23:18	GET	http://localhost:3000/assets/public/css/robots.css	200	OK	8 ms	180 bytes			
2070	Proxy	21/05/2020, 19:23:18	GET	http://localhost:3000/vendor/material-icons/material-icons	200	OK	8 ms	3,314 bytes			
2071	Proxy	21/05/2020, 19:23:18	GET	http://localhost:3000/vendor/beers/beers-main.js	200	OK	9 ms	11,670 bytes			Password, Upload
2073	Proxy	21/05/2020, 19:23:18	GET	http://localhost:3000/vendor/beers/beers-main.css	200	OK	22 ms	80,191 bytes			
2074	Proxy	21/05/2020, 19:23:18	GET	http://localhost:3000/vendor/fortsource-robot/700.css	200	OK	6 ms	5,431 bytes			
2075	Proxy	21/05/2020, 19:23:18	GET	http://localhost:3000/vendor/fortsource-robot/500.css	200	OK	6 ms	5,431 bytes			
2076	Proxy	21/05/2020, 19:23:18	GET	http://localhost:3000/vendor/fortsource-robot/300.css	200	OK	7 ms	5,431 bytes			
2077	Proxy	21/05/2020, 19:23:18	GET	http://localhost:3000/vendor/fortsource-robot/400.css	200	OK	7 ms	5,431 bytes			
2082	Proxy	21/05/2020, 19:23:19	GET	http://localhost:3000/vendor/fortsource-robot/robot.html	200	OK	7 ms	21,684 bytes			
2083	Proxy	21/05/2020, 19:23:19	GET	http://localhost:3000/vendor/fortsource-robot/files/robot	200	OK	6 ms	22,200 bytes			
2084	Proxy	21/05/2020, 19:23:19	GET	http://localhost:3000/vendor/material-icons/material-icons	200	OK	7 ms	129,352 bytes			

Gambar 20. History Saat Mengubah Username

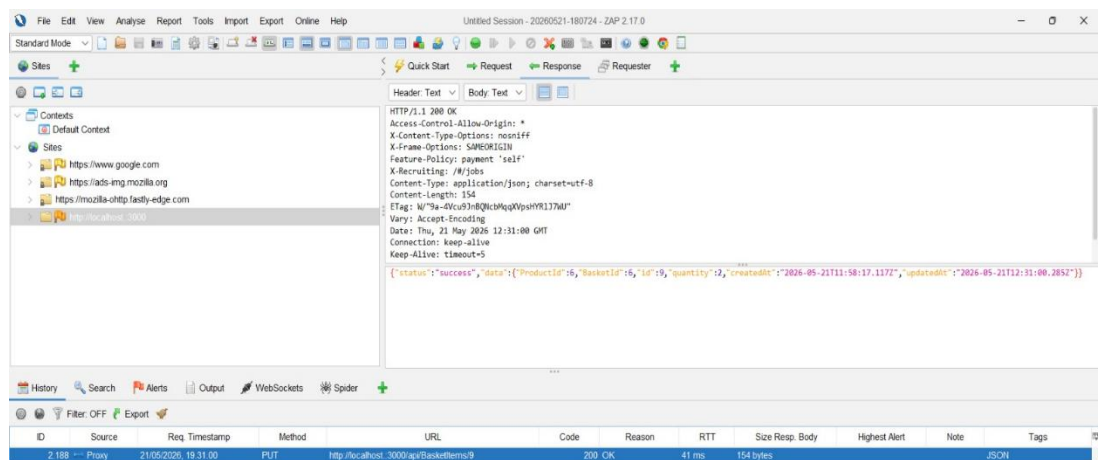
6. Halaman keranjang

ID	Source	Req. Timestamp	Method	URL	Code	Reason	RTT	Size Resp. Body	Highest Alert	Note	Tags
2188	Proxy	21/05/2020, 19:30:57	GET	http://localhost:3000/rest/basket/6	304	Not Modified	40 ms	0 bytes			
2187	Proxy	21/05/2020, 19:31:00	GET	http://localhost:3000/api/BasketItems/9	200	OK	34 ms	154 bytes			JSON
2188	Proxy	21/05/2020, 19:31:00	PUT	http://localhost:3000/api/BasketItems/9	200	OK	41 ms	154 bytes			JSON
2189	Proxy	21/05/2020, 19:31:00	GET	http://localhost:3000/rest/basket/6	200	OK	38 ms	1,300 bytes			JSON
2190	Proxy	21/05/2020, 19:31:00	GET	http://localhost:3000/rest/basket/6	200	OK	48 ms	1,300 bytes			JSON
2191	Proxy	21/05/2020, 19:31:13	POST	https://img-mozzila-ohp.fastly-edge.com/	200	OK	428 ms	11,118 bytes			Comment
2192	Proxy	21/05/2020, 19:32:10	DELETE	http://localhost:3000/api/BasketItems/10	200	OK	41 ms	30 bytes			JSON
2193	Proxy	21/05/2020, 19:32:10	GET	http://localhost:3000/rest/basket/6	200	OK	29 ms	900 bytes			JSON
2194	Proxy	21/05/2020, 19:32:10	GET	http://localhost:3000/rest/basket/6	200	OK	28 ms	900 bytes			
2195	Proxy	21/05/2020, 19:32:11	DELETE	http://localhost:3000/api/BasketItems/11	200	OK	35 ms	30 bytes			JSON
2196	Proxy	21/05/2020, 19:32:11	GET	http://localhost:3000/rest/basket/6	200	OK	31 ms	529 bytes			
2197	Proxy	21/05/2020, 19:32:11	GET	http://localhost:3000/rest/basket/6	200	OK	26 ms	529 bytes			
2198	Proxy	21/05/2020, 19:32:12	GET	http://localhost:3000/api/BasketItems/9	200	OK	22 ms	154 bytes			JSON

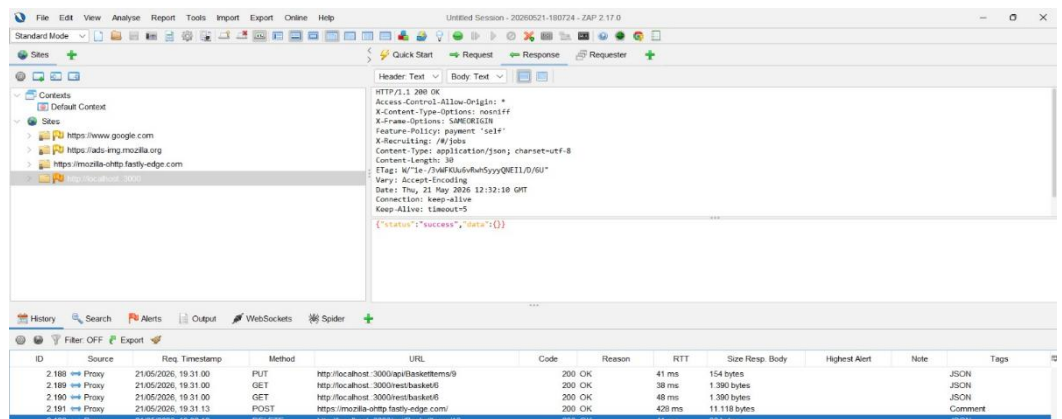
Gambar 21. History Saat Masukin Keranjang, Menambahkan Kuantitas dan Hapus Barang dari Keranjang



Gambar 22. Respon Saat Masukin Keranjang

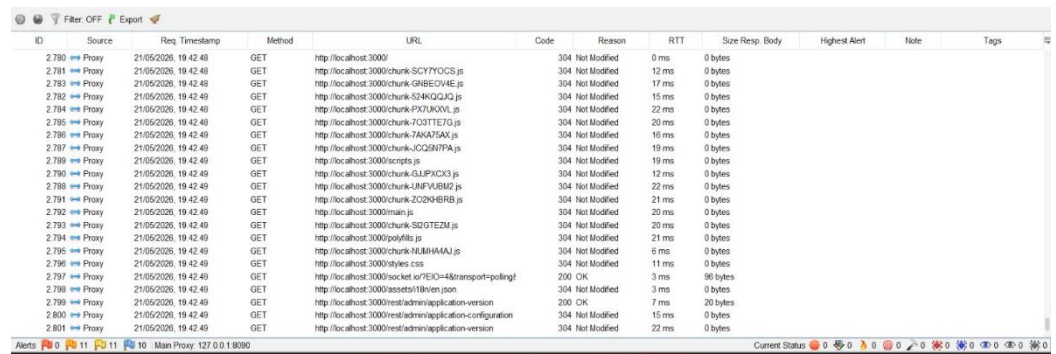


Gambar 23. Respon Saat Menambah Kuantitas Item



Gambar 24. Respon Saat Menghapus Item Keranjang

7. Halaman admin



ID	Source	Req. Timestamp	Method	URL	Code	Reason	RTT	Size Resp. Body	Highest Alert	Note	Tags
2780	Proxy	21/05/2026, 19:42:48	GET	http://localhost:3000/	304	Not Modified	0 ms	0 bytes			
2781	Proxy	21/05/2026, 19:42:48	GET	http://localhost:3000/chunk-SCY7YOC5.js	304	Not Modified	12 ms	0 bytes			
2783	Proxy	21/05/2026, 19:42:48	GET	http://localhost:3000/chunk-SMBEC34E.js	304	Not Modified	17 ms	0 bytes			
2782	Proxy	21/05/2026, 19:42:48	GET	http://localhost:3000/chunk-S24KQJQJ.js	304	Not Modified	15 ms	0 bytes			
2784	Proxy	21/05/2026, 19:42:48	GET	http://localhost:3000/chunk-PX7UKXVL.js	304	Not Modified	22 ms	0 bytes			
2785	Proxy	21/05/2026, 19:42:48	GET	http://localhost:3000/chunk-7O3TTE7G.js	304	Not Modified	20 ms	0 bytes			
2786	Proxy	21/05/2026, 19:42:49	GET	http://localhost:3000/chunk-7AKA75AX.js	304	Not Modified	16 ms	0 bytes			
2787	Proxy	21/05/2026, 19:42:49	GET	http://localhost:3000/chunk-JCQ2H7PA.js	304	Not Modified	19 ms	0 bytes			
2789	Proxy	21/05/2026, 19:42:49	GET	http://localhost:3000/scripts.js	304	Not Modified	19 ms	0 bytes			
2790	Proxy	21/05/2026, 19:42:49	GET	http://localhost:3000/chunk-GJUPXCX3.js	304	Not Modified	12 ms	0 bytes			
2788	Proxy	21/05/2026, 19:42:49	GET	http://localhost:3000/chunk-JUNFVBM2.js	304	Not Modified	22 ms	0 bytes			
2791	Proxy	21/05/2026, 19:42:49	GET	http://localhost:3000/chunk-ZO2K4BRB.js	304	Not Modified	21 ms	0 bytes			
2792	Proxy	21/05/2026, 19:42:49	GET	http://localhost:3000/main.js	304	Not Modified	20 ms	0 bytes			
2793	Proxy	21/05/2026, 19:42:49	GET	http://localhost:3000/chunk-SDGTEZM.js	304	Not Modified	20 ms	0 bytes			
2794	Proxy	21/05/2026, 19:42:49	GET	http://localhost:3000/polyfills.js	304	Not Modified	21 ms	0 bytes			
2795	Proxy	21/05/2026, 19:42:49	GET	http://localhost:3000/chunk-NUMHAAUJ.js	304	Not Modified	6 ms	0 bytes			
2796	Proxy	21/05/2026, 19:42:49	GET	http://localhost:3000/styles.css	304	Not Modified	11 ms	0 bytes			
2797	Proxy	21/05/2026, 19:42:49	GET	http://localhost:3000/socket.io/?EIO=4&transport=polling/	200	OK	3 ms	96 bytes			
2798	Proxy	21/05/2026, 19:42:49	GET	http://localhost:3000/scripts/180/en/zoom	304	Not Modified	3 ms	0 bytes			
2799	Proxy	21/05/2026, 19:42:49	GET	http://localhost:3000/rest/admin/application-version	200	OK	7 ms	20 bytes			
2800	Proxy	21/05/2026, 19:42:49	GET	http://localhost:3000/rest/admin/application-configuration	304	Not Modified	15 ms	0 bytes			
2801	Proxy	21/05/2026, 19:42:49	GET	http://localhost:3000/rest/admin/application-version	304	Not Modified	22 ms	0 bytes			

Alerts 0 11 10 Main Proxy: 127.0.0.1:8080 Current Status: 0

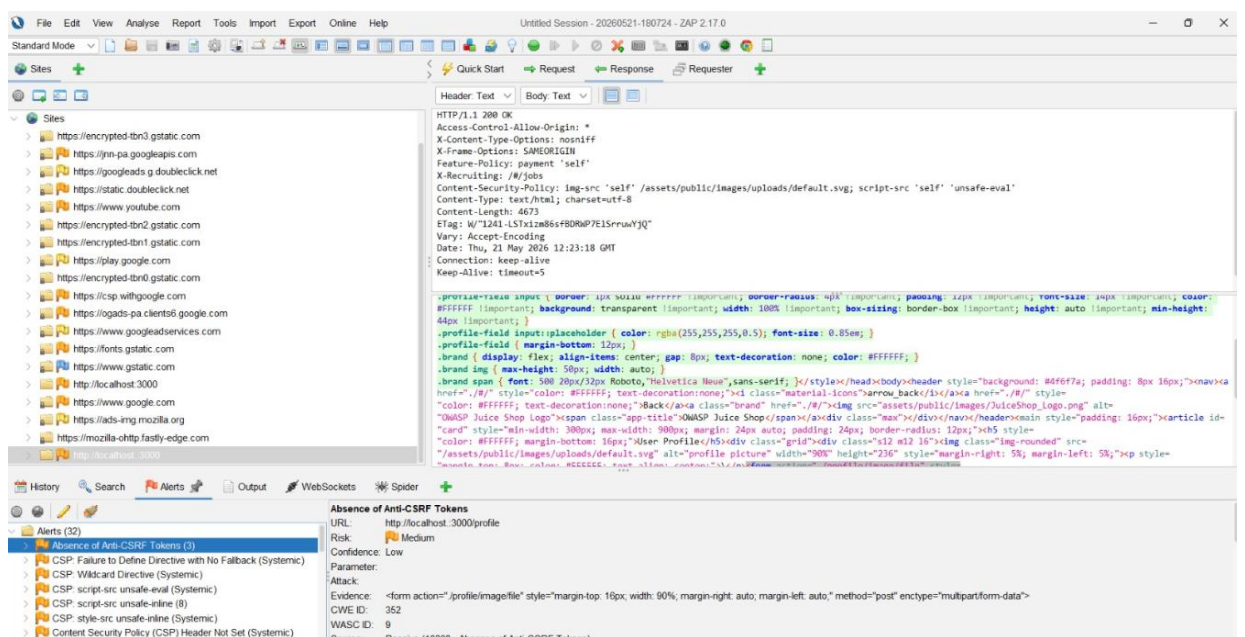
Gambar 25. History Gagal Masuk Sebagai Admin

HASIL TEMUAN KEAMANAN

Berikut adalah tiga temuan keamanan utama yang ditemukan selama pengujian OWASP Juice Shop menggunakan OWASP ZAP. Setiap temuan dilengkapi dengan lokasi endpoint, bukti teknis, tingkat risiko, dampak, dan rekomendasi perbaikan.

Temuan 1 Absence of Anti-CSRF Tokens	
Judul Temuan	Absence of Anti-CSRF Tokens
Lokasi Endpoint	http://localhost:3000/profile
Metode Pengujian	Passive Scan — OWASP ZAP (Passive Scanner 10202) mendeteksi form HTML dengan method POST yang tidak memiliki token CSRF. Alert ditemukan secara otomatis pada tab Alerts ZAP saat browser mengakses halaman /profile.
Bukti Teknis	Alert ZAP: Absence of Anti-CSRF Tokens Risk : Medium Confidence : Low CWE ID : 352 WASP ID : 9 Source : Passive (10202 - Absence of Anti-CSRF Tokens) Evidence (form tanpa token CSRF): <form action="/profile/image/file" style="margin-top: 16px; width: 90%; margin-right: auto; margin-left: auto;" method="post" enctype="multipart/form-data"> Header Response yang Teramati: HTTP/1.1 200 OK Access-Control-Allow-Origin: * X-Content-Type-Options: nosniff X-Frame-Options: SAMEORIGIN Feature-Policy: payment 'self' Content-Security-Policy: img-src 'self' /assets/public/images/uploads/default.svg; script-src 'self' 'unsafe-eval' Content-Type: text/html; charset=utf-8 Date: Thu, 21 May 2026 12:23:18 GMT Connection: keep-alive
Tingkat Risiko	MEDIUM Form POST pada /profile tidak dilindungi token CSRF sehingga rentan terhadap serangan Cross-Site Request Forgery.
Dampak	Tanpa token Anti-CSRF, penyerang dapat membuat halaman web berbahaya yang secara diam-diam mengirimkan request POST ke /profile/image/file atas nama pengguna yang sedang login.

	Hal ini dapat dimanfaatkan untuk mengubah foto profil atau data pengguna tanpa sepengetahuan korban (CWE-352: Cross-Site Request Forgery). Meskipun confidence ZAP bernilai Low (karena ZAP tidak dapat memverifikasi sepenuhnya secara pasif), keberadaan form POST tanpa token CSRF merupakan praktik yang tidak aman.
Rekomendasi	Tambahkan token CSRF yang unik dan tidak dapat ditebak pada setiap form POST: - Gunakan library CSRF protection di sisi server, contoh untuk Express.js: <pre>const csrf = require('csrf'); app.use(csrf());</pre> - Sertakan token CSRF sebagai hidden field pada setiap form: <pre><input type="hidden" name="_csrf" value="<%= csrfToken() %>"></pre> - Validasi token di sisi server sebelum memproses setiap request POST. - Pertimbangkan penggunaan header SameSite=Strict pada cookie sesi sebagai lapisan perlindungan tambahan.

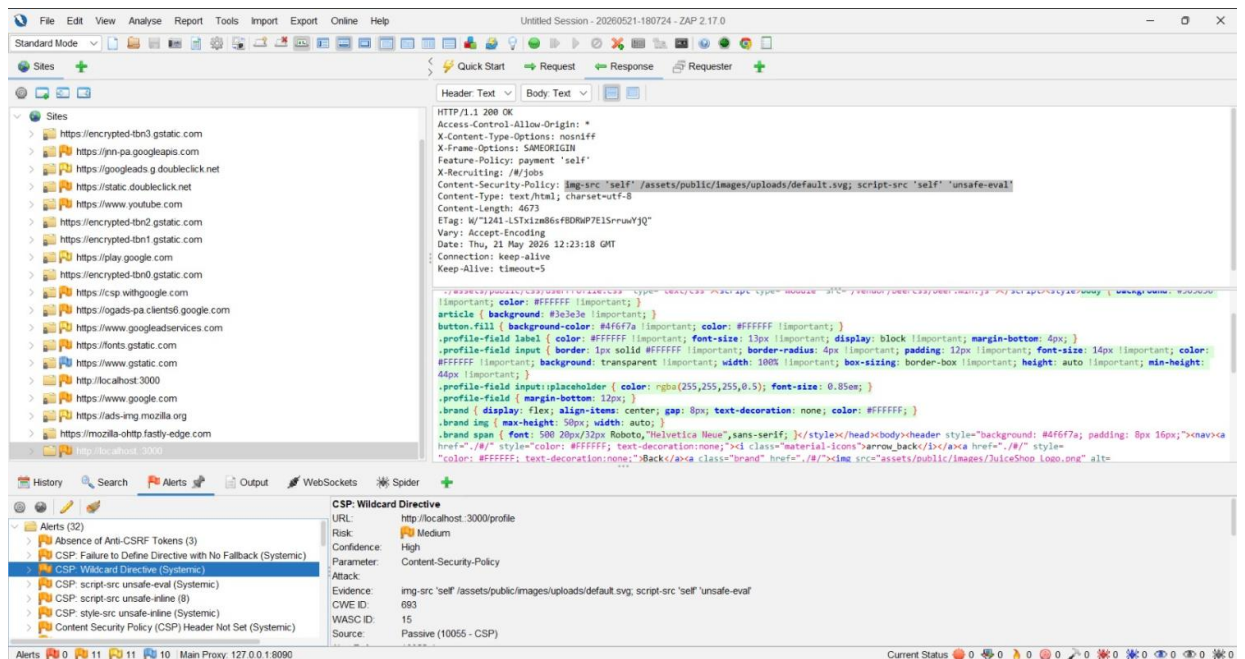


Gambar 26. Bukti Temuan 1

Temuan 2 CSP: Wildcard Directive	
Judul Temuan	CSP: Wildcard Directive
Lokasi Endpoint	http://localhost:3000/profile
Metode Pengujian	Passive Scan — OWASP ZAP (Passive Scanner 10055 - CSP) mendeteksi penggunaan wildcard atau directive tidak aman pada header Content-Security-Policy.

	Alert ditemukan pada tab Alerts ZAP dengan confidence High saat mengakses halaman /profile.
Bukti Teknis	Alert ZAP: CSP: Wildcard Directive Risk : Medium Confidence : High Parameter : Content-Security-Policy CWE ID : 693 WASC ID : 15 Source : Passive (10055 - CSP) Evidence — Nilai CSP yang bermasalah: Content-Security-Policy: img-src 'self' /assets/public/images/uploads/default.svg; script-src 'self' 'unsafe-eval' Header Response Lengkap: HTTP/1.1 200 OK Access-Control-Allow-Origin: * X-Content-Type-Options: nosniff X-Frame-Options: SAMEORIGIN Feature-Policy: payment 'self' Content-Security-Policy: img-src 'self' /assets/public/images/uploads/default.svg; script-src 'self' 'unsafe-eval' Content-Type: text/html; charset=utf-8 Date: Thu, 21 May 2026 12:23:18 GMT
Tingkat Risiko	MEDIUM CSP mengandung directive 'unsafe-eval' yang membuka celah eksekusi skrip berbahaya meski CSP sudah dikonfigurasi.
Dampak	Directive 'unsafe-eval' pada script-src mengizinkan penggunaan fungsi eval(), Function(), setTimeout(string), dan setInterval(string) di browser. Hal ini melemahkan perlindungan CSP secara signifikan karena penyerang yang berhasil menyuntikkan skrip dapat mengeksekusi kode arbitrer melalui eval() meski CSP sudah ada. Selain itu, header Access-Control-Allow-Origin: * membuka akses lintas domain tanpa pembatasan, yang dapat dimanfaatkan untuk serangan CORS. CWE-693 (Protection Mechanism Failure) — mekanisme perlindungan yang dikonfigurasi tidak memberikan perlindungan penuh karena directive yang lemah.
Rekomendasi	1. Hapus 'unsafe-eval' dari directive script-src:

	Content-Security-Policy: default-src 'self'; script-src 'self'; img-src 'self'; object-src 'none' 2. Jika 'unsafe-eval' diperlukan oleh library tertentu, pertimbangkan menggantinya dengan nonce atau hash: script-src 'self' 'nonce-{random_nonce}' 3. Batasi Access-Control-Allow-Origin hanya ke domain yang benar-benar diizinkan, hindari penggunaan wildcard (*). 4. Tambahkan directive yang hilang: default-src, object-src, frame-ancestors untuk cakupan CSP yang lebih lengkap.
--	--

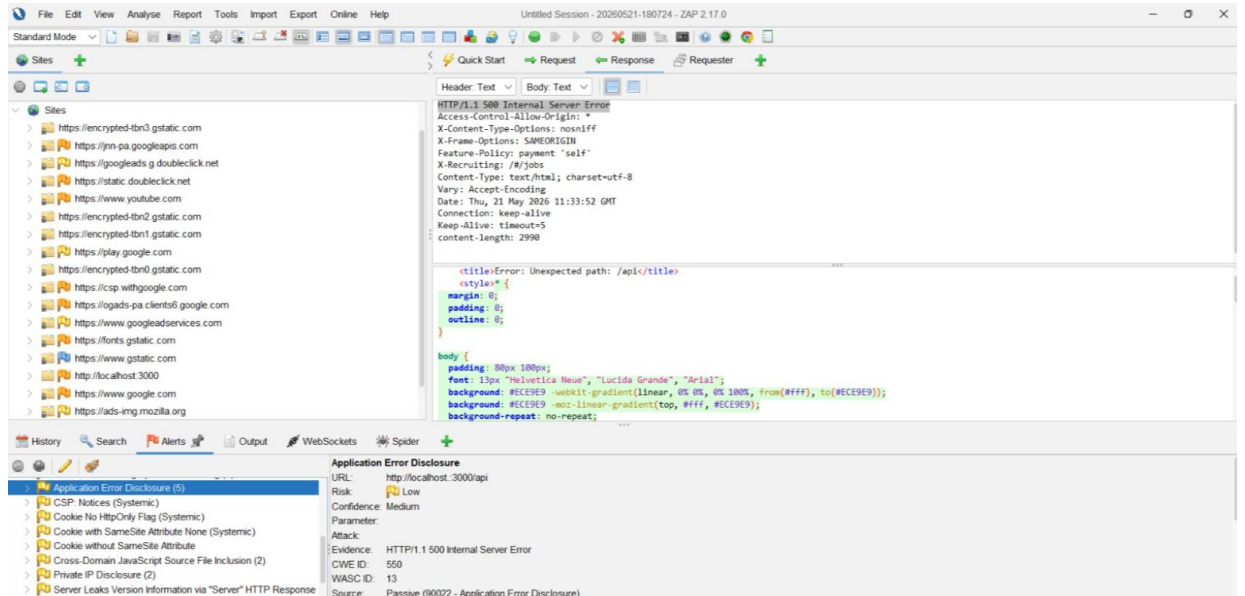


Gambar 27. Bukti Temuan 2

Temuan 3 Application Error Disclosure	
Judul Temuan	Application Error Disclosure
Lokasi Endpoint	http://localhost:3000/api
Metode Pengujian	Passive Scan — OWASP ZAP (Passive Scanner 90022 - Application Error Disclosure) mendeteksi respons server yang mengekspos pesan error internal. Alert ditemukan pada tab Alerts ZAP dengan confidence Medium saat mengakses endpoint /api.
Bukti Teknis	Alert ZAP: Application Error Disclosure Risk : Low Confidence : Medium CWE ID : 550 WASC ID : 13

	Source : Passive (90022 - Application Error Disclosure) Evidence — Pesan error yang terekspos: HTTP/1.1 500 Internal Server Error <title>Error: Unexpected path: /api</title> Header Response Lengkap: HTTP/1.1 500 Internal Server Error Access-Control-Allow-Origin: * X-Content-Type-Options: nosniff X-Frame-Options: SAMEORIGIN Feature-Policy: payment 'self' X-Recruiting: /#/jobs Content-Type: text/html; charset=utf-8 Date: Thu, 21 May 2026 11:33:52 GMT content-length: 2990
Tingkat Risiko	LOW Server mengembalikan HTTP 500 disertai detail path internal ('Unexpected path: /api') yang dapat membantu penyerang memetakan struktur aplikasi.
Dampak	Pesan error HTTP 500 yang ditampilkan kepada pengguna mengandung informasi internal seperti path ('/api') dan struktur routing aplikasi. Informasi ini dapat dimanfaatkan penyerang untuk teknik enumerasi — memahami struktur backend, framework yang digunakan, dan endpoint yang tersedia. CWE-550 (Server-generated Error Message Containing Sensitive Information) — server secara tidak sengaja membocorkan detail teknis yang seharusnya tidak terekspos ke publik. Meskipun risiko langsung tergolong Low, informasi ini sering menjadi langkah awal dalam reconnaissance sebelum serangan yang lebih serius.
Rekomendasi	1. Ganti pesan error HTTP 500 dengan halaman error generik yang tidak mengekspos detail internal: Contoh: "Terjadi kesalahan pada server. Silakan coba beberapa saat lagi." 2. Tangani error di sisi server menggunakan middleware error handling di Express.js: <pre>app.use((err, req, res, next) => { res.status(500).json({ error: 'Internal Server Error' }); });</pre> 3. Catat detail error pada server-side log (bukan dikirimkan ke client) untuk keperluan debugging.

4. Nonaktifkan mode debug/development pada environment production.



Gambar 28. Bukti Temuan 3

VALIDASI MANUAL TEMUAN

Temuan yang Divalidasi

Dari tiga temuan yang ditemukan menggunakan OWASP ZAP, temuan yang dipilih untuk divalidasi secara manual adalah:

Temuan yang Divalidasi	Cookie Sesi Tanpa Atribut Keamanan (Missing Cookie Security Flags)
Keterkaitan dengan Temuan Sebelumnya	Berkaitan langsung dengan Temuan 1 (Absence of Anti-CSRF Tokens) dan Temuan 2 (CSP: Wildcard Directive) — ketiganya berpusat pada endpoint /profile
Endpoint	http://localhost:3000/profile (Method: POST)
Alasan Dipilih	Cookie sesi (JWT token) ditemukan tanpa flag HttpOnly, Secure, dan SameSite — dapat divalidasi langsung dari header response tanpa perlu eksploitasi agresif

Langkah Validasi Manual

Validasi dilakukan dengan memeriksa secara langsung header Set-Cookie pada response HTTP dari endpoint /profile menggunakan fitur Search dan tab Response di OWASP ZAP. Tidak ada eksploitasi aktif yang dilakukan — validasi bersifat observasional terhadap lalu lintas HTTP yang sudah tertangkap.

1. Buka OWASP ZAP dan pastikan Firefox terhubung ke proxy 127.0.0.1:8090.
2. Akses OWASP Juice Shop di http://localhost:3000 dan lakukan login dengan akun yang sudah dibuat.
3. Navigasi ke halaman Profile (http://localhost:3000/profile) — tindakan ini akan memicu request POST ke /profile.
4. Di ZAP, buka tab Search dan ketik kata kunci "profile" pada kolom pencarian, lalu klik Search.
5. Dari hasil pencarian, pilih baris POST http://localhost:3000/profile yang berwarna biru (highlighted).
6. Pada panel kanan atas, klik tab Response untuk melihat header HTTP yang dikirimkan server.
7. Amati header Set-Cookie pada response — catat seluruh atribut yang tercantum dan yang tidak ada.
8. Bandingkan nilai cookie yang diterima dengan standar keamanan (HttpOnly, Secure, SameSite).

Hasil Validasi

A. Konteks Request yang Divalidasi

Method	POST
URL	http://localhost:3000/profile
Sumber Data	Tab Search ZAP — kata kunci: "profile", Number of Matches: 283
Status Response	200 OK (beserta redirect ke /profile via Location header)

B. Header Response yang Diamati

Berikut adalah isi header HTTP response yang diterima dari server pada request POST ke /profile:

HTTP/1.1 200 OK

X-Recruiting: /#/jobs

Set-Cookie: token=eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.

eyJzdGF0dXMiOiJzdWNjZXRzLiwiZGF0YSI6eyJpZCI6...[JWT
dipotong]...; Path=

Location: /profile

Catatan penting: Nilai cookie diawali dengan eyJhbGci... — ini adalah format standar JSON Web Token (JWT) yang digunakan sebagai token autentikasi sesi pengguna.

C. Analisis Atribut Cookie

Atribut Cookie	Nilai yang Ditemukan	Status	Keterangan
Nama	token	—	Token autentikasi sesi (JWT)
Nilai	eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9...	—	JSON Web Token — sensitif
Path	/	Ada	Cookie berlaku untuk seluruh path aplikasi
HttpOnly	(tidak tercantum)	TIDAK ADA	Token JWT dapat diakses via JavaScript
Secure	(tidak tercantum)	TIDAK ADA	Cookie dikirim meski via HTTP biasa
SameSite	(tidak tercantum)	TIDAK ADA	Rentan CSRF lintas situs
Expires / Max-Age	(tidak tercantum)	Tidak Ada	Cookie bersifat session cookie

D. Keterkaitan dengan Ketiga Temuan

Temuan	Kaitan dengan Validasi Ini
Temuan 1 — Absence of Anti-CSRF Tokens	Form POST /profile tanpa token CSRF + cookie tanpa SameSite = kombinasi yang memperparah risiko CSRF. Penyerang dapat

	memaksa browser korban mengirim request POST sambil cookie dikirimkan otomatis.
Temuan 2 — CSP: Wildcard Directive	CSP yang lemah (unsafe-eval) + cookie tanpa HttpOnly = jika XSS berhasil dieksekusi, token JWT langsung dapat dicuri via document.cookie karena tidak ada proteksi HttpOnly.
Temuan (Validasi) — Tambahan Missing Cookie Flags	Terbukti valid secara manual: Set-Cookie hanya memiliki Path=/ tanpa HttpOnly, Secure, atau SameSite — token JWT sesi pengguna tidak terlindungi di sisi browser.

E. Kesimpulan Validasi

Validasi manual terhadap header response HTTP dari endpoint POST /profile membuktikan bahwa server Juice Shop mengeluarkan cookie sesi berisi JWT token tanpa mencantumkan atribut keamanan kritis.

Dari baris Set-Cookie yang diamati langsung di ZAP:

- Atribut HttpOnly tidak ada — token JWT dapat dibaca langsung oleh JavaScript sisi klien melalui document.cookie.
- Atribut Secure tidak ada — cookie dikirimkan meski koneksi tidak menggunakan HTTPS, sehingga rentan terhadap sniffing pada jaringan tidak terenkripsi.
- Atribut SameSite tidak ada — cookie akan ikut dikirimkan pada setiap cross-site request, memperparah risiko serangan CSRF yang sudah ditemukan pada Temuan 1.

Kombinasi ketiga kelemahan ini (**Anti-CSRF Token yang hilang + CSP yang lemah + Cookie tanpa flag keamanan**) menciptakan rantai kerentanan yang dapat berujung pada **session hijacking (pengambilalihan sesi akun pengguna)** jika dieksploitasi secara bersamaan.

Validasi ini dilakukan sepenuhnya secara pasif — hanya dengan membaca header response HTTP yang sudah tertangkap oleh ZAP tanpa melakukan injeksi, brute force, atau eksploitasi aktif apapun, sesuai dengan batasan etik praktikum.

REKOMENDASI PERBAIKAN

Berdasarkan temuan keamanan yang diperoleh selama praktikum, berikut adalah rekomendasi perbaikan yang spesifik dan dapat diterapkan pada konfigurasi OWASP Juice Shop maupun aplikasi web serupa:

No	Temuan	Rekomendasi	Implementasi Teknis
1	Missing CSP Header	Aktifkan Content-Security-Policy	Tambahkan header: Content-Security-Policy: default-src 'self'; script-src 'self'
2	Cookie Tanpa HttpOnly	Tambahkan atribut HttpOnly dan Secure	Set-Cookie: token=...; HttpOnly; Secure; SameSite=Strict
3	Application Error Disclosure	Tangani error di sisi server menggunakan middleware error handling di Express.js	<pre>app.use((err, req, res, next) => { res.status(500).json({ error: 'Internal Server Error' }); });</pre>

Rekomendasi Tambahan

- A. Tambahkan header X-Frame-Options: DENY atau SAMEORIGIN untuk mencegah clickjacking.
 - B. Tambahkan header X-Content-Type-Options: nosniff untuk mencegah MIME sniffing.
 - C. Gunakan Strict-Transport-Security (HSTS) jika aplikasi berjalan di HTTPS.
 - D. Terapkan validasi input sisi server untuk semua parameter yang diterima dari pengguna.
 - E. Gunakan pesan error generik (jangan ekspos detail stack trace atau nama framework).
 - F. Pisahkan hak akses pengguna biasa dan admin pada endpoint sensitif.
-

KESIMPULAN

Praktikum analisis keamanan aplikasi web menggunakan OWASP ZAP terhadap OWASP Juice Shop telah berhasil dilaksanakan. Selama praktikum, browser Firefox dikonfigurasi untuk meneruskan seluruh lalu lintas HTTP melalui ZAP pada alamat 127.0.0.1 port 8090, sehingga seluruh komunikasi antara browser dan aplikasi target dapat diamati secara mendetail.

Melalui fitur passive scan, spidering, dan analisis manual, kelompok berhasil mengidentifikasi setidaknya tiga temuan keamanan pada OWASP Juice Shop. Temuan-temuan tersebut mencakup permasalahan pada konfigurasi header keamanan HTTP, atribut cookie sesi, dan [ISI: sebutkan temuan ketiga]. Seluruh temuan disertai bukti teknis dari lalu lintas HTTP yang tertangkap oleh ZAP.

Validasi manual terhadap temuan [ISI: nama temuan] membuktikan bahwa alert yang dihasilkan oleh ZAP dapat dikonfirmasi secara langsung melalui pemeriksaan header dan response HTTP, bukan sekadar mengandalkan laporan otomatis dari alat.

Praktikum ini memberikan pemahaman praktis mengenai cara kerja proxy HTTP dalam pengujian keamanan, pentingnya konfigurasi header keamanan, serta metode dasar identifikasi dan validasi kerentanan aplikasi web. Seluruh pengujian dilaksanakan dalam lingkungan lokal yang terisolasi sesuai pernyataan etik praktikum.

DAFTAR PUSTAKA

No	Referensi
1	OWASP Foundation. (2024). OWASP Juice Shop. https://owasp.org/www-project-juice-shop/
2	OWASP Foundation. (2024). OWASP ZAP: Zed Attack Proxy. https://www.zaproxy.org/
3	OWASP Foundation. (2021). OWASP Top Ten. https://owasp.org/www-project-top-ten/
4	Mozilla Developer Network. (2024). Content-Security-Policy. MDN Web Docs. https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Content-Security-Policy
5	MITRE Corporation. (2023). CWE-352: Cross-Site Request Forgery (CSRF). Common Weakness Enumeration. https://cwe.mitre.org/data/definitions/352.html
6	MITRE Corporation. (2023). CWE-693: Protection mechanism failure. Common Weakness Enumeration. https://cwe.mitre.org/data/definitions/693.html
7	MITRE Corporation. (2023). CWE-550: Server-generated error message containing sensitive information. Common Weakness Enumeration. https://cwe.mitre.org/data/definitions/550.html
8	Mozilla Developer Network. (2024). Set-Cookie. MDN Web Docs. https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Set-Cookie
9	Jones, M., Bradley, J., & Sakimura, N. (2015). JSON Web Token (JWT) (RFC 7519). Internet Engineering Task Force. https://datatracker.ietf.org/doc/html/rfc7519
